Portability audit, 2026-10-29

English version of ../../audit/portability-audit-2026-10-29.md (the Russian page carries the full detail; this one keeps the same structure and the same conclusions).

What was already in good shape

Area	Observation
Structure	`app/domain`, `app/http_api`, `app/realtime`, `app/services` — the layers exist
Tests	10 files, **190 tests pass** on an isolated `DATA_DIR` without external services
Containers	multi-stage `Dockerfile`, non-root `appuser`, HEALTHCHECK, data volume
Resilience to a missing AI	offline question bank when `GIGACHAT_CREDENTIALS` is empty
Compose	fail-closed on mandatory secrets (`${VAR:?…}`)
Documentation	README, ROADMAP, CHANGELOG, SECURITY, CONTRIBUTING

Gaps and what was done

#	Gap	Impact	Closed by
1	**`.env` committed with a working GigaChat key**	secret leak despite `.gitignore`	file removed from the index, `gitleaks` added to CI, incident described in `docs/security/secrets.md`
2	**CI did not exist at all**	nobody ran the 190 tests automatically	`.github/workflows/ci.yml`: tests, ruff, start without AI, image build + health, secrets, docs
3	Dependencies given as ranges (`>=`, `<`)	two installations at different times give different versions	`requirements.lock.txt` (37 packages) + `make lock`
4	No `Makefile`	commands scattered	`Makefile` with 17 targets
5	No host check and no smoke test	"it does not work" was discovered after start-up	`scripts/doctor.sh`, `scripts/smoke-test.sh`
6	No documentation completeness check	documents rot silently	`scripts/docs-check.sh`
7	No architecture document with boundaries	layers exist in code but were not written down	`docs/architecture/system-context.md`
8	No module specifications	boundaries not verifiable	`docs/modules/*` (3 specifications + template)
9	No "claim → check" matrix	proven and promised were indistinguishable	`docs/verification/matrix.md`
10	Two SQLite databases undocumented	no reason given for the split	`docs/database/storage.md`

Critical for the owner

Key rotation is mandatory: `GIGACHAT_CREDENTIALS`, `SECRET_KEY`, `ADMIN_SECRET_KEY`, `CHEAT_TESTER_CODE`. Deleting the file does not revoke a leaked key.

What is still open

- The history rewrite was later performed (2026-10-29) — see ../security/secrets.md.
- No `/metrics` and no SLO.
- One process: rooms in memory, several replicas unsupported.
- No automated backup/restore check for SQLite.

Appendix: what the first CI run found

Symptom	Real cause	Fixed
The "No committed secrets" job failed with `missing gitleaks license`	`gitleaks/gitleaks-action@v2` requires a paid licence for organisations and checks nothing without it	the action was replaced by downloading a pinned gitleaks (8.28.0) and running it directly: working-tree scan is blocking, full-history scan is informational until the key is revoked
The "Tests, lint" job failed on lint (324 findings)	no ruff configuration: the result depended on the version, and the whole strict set was blocking	`ruff.toml` with an explicit blocking set (`E9`, `F`), 14 real findings fixed; style debt documented in `docs/development/code-style.md`
The container failed its health check (`ADMIN_SECRET_KEY must be at least 12 characters`)	CI passed a short key that the configuration validator rejects — the check was right, the test data was wrong	CI now passes a key of the required length; the validator check stays
Checks installed the "latest" pytest/ruff from PyPI	non-reproducibility: rule sets and behaviour change without code changes	`requirements-dev.txt` with exact pins; CI installs from it

Appendix: cleaning secrets out of the history (2026-10-29)

A full-history scan (`gitleaks git`, all 7 repositories) found secrets in three of them:

Repository	Found	Where
ForgeBrainStorm	`.env` with a GigaChat key (`client_id:client_secret`)	8 commits, the `.env` file
ForgeInterio	a Telegram bot token and a base64 key	`bot/main.py`, `DEPLOY_RENDER.md`
ForgeAezaAnalizer	`.env.before-telegram-*` with `JWT_SECRET`/`POSTGRES_PASSWORD`/`ADMIN_PASSWORD` (demo values), a `db/auth.sqlite3` dump	2 commits

What was done: `git filter-repo` in BrainStorm (99 commits) and `--replace-text` in Interio and Aeza; force-push of all branches and tags; verification with `gitleaks git` on fresh clones shows 0 findings. The keys still have to be rotated: a rewrite removes the secret from the repository, not from the internet. Old objects remain reachable through `refs/pull/*` until GitHub Support removes them.